NEBA CS

Medical Waste Management Platform

System Architecture Document

Architecture, data design, workflows, APIs, security, integrations, deployment and recommended enhancements

Version	1.2 — implementation baseline (6 roles; OTP to Clerk-verified hospital users)
Date	7 October 2026
Prepared by	Trhas (developer)
Prepared for	Client (owner of the disposal company) and the development team
Based on	Client specification (30 Sep 2026), client decisions (incl. 5 Oct 2026 role and OTP update), System Architecture blueprint (Next.js, Clerk, Neon), CLAUDE.md
Stack	Next.js (App Router) · Clerk · Neon PostgreSQL · Drizzle ORM · Leaflet + OpenStreetMap

How to read this document

Sections 1–4 explain **what** the system is and **why** it is designed this way. Sections 5–8 describe **how it works inside**: modules, data, statuses and step-by-step flows. Sections 9–13 are the **engineering rules**: APIs, security, integrations, deployment and quality. Section 14 lists the **enhancements** added to the original design. A glossary in Section 1.4 explains every technical term in simple words.

What Changed in Version 1.1

Change	Before (v1.0)	v1.2 implementation baseline
Number of roles	8 roles	**6 roles**: Super Administrator, Hospital Administrator, Hospital Staff / EHO, Fleet Driver, Disposal Operator, EFDA Regulatory & Audit Officer
Finance	Separate Finance Officer role and /finance area	Merged into **Super Administrator**: contracts, invoices (ETB) and settlement are part of /admin
Auditing	Separate Auditor role	Merged into **EFDA Regulatory & Audit Officer** (/regulator, read-only)
Who receives the OTP	An "authorized contact" (phone + email) stored on the facility, who might have no account	The facility's **own hospital users** (Hospital Staff / Hospital Admin) whose phone numbers are **verified through Clerk**; code sent by the **Ethio Telecom SMS API**. No separate contacts.
OTP backup	Email copy of the code	**In-app handover confirmation**: a signed-in user of the same facility can confirm the pickup on /hospital if the SMS does not arrive. Super Admin override stays as last resort.
Consequence	A facility could work without user accounts	Every facility needs **at least one active hospital user with a verified phone** before pickups can be scheduled
Pickup completion	A stop could become COLLECTED after ≥1 scan.	V1 requires every expected container to be accounted for: all containers must be scanned before OTP/in-app/override can complete the stop. Partial pickup is not a successful pickup.
Container scanning	A scan could directly make a container COLLECTED.	A scan first records SCANNED_AT_PICKUP evidence. Only successful stop completion changes all scanned containers to COLLECTED in the same transaction.
OTP lifecycle	OTP had ISSUED/VERIFIED/EXPIRED/LOCKED.	Adds CANCELLED. Active OTPs are invalidated on skip, cancellation or allowed reassignment.
Disposal accounting	Waste could become RECEIVED when at least one container was received and the rest were exceptions.	Every container must end in RECEIVED, MISSING or REFUSED before the waste can leave IN_TRANSIT. Destruction/certificate logic distinguishes complete destruction from destruction with exceptions.
Certificate generation	Destruction could be described as immediately issuing a certificate.	Destruction is committed first and locked. Certificate generation is asynchronous with PENDING/ISSUED/FAILED/REVOKED states and retry; certificate failure never rolls back destruction.
Trip reassignment	Reassignment had no explicit timing restriction.	V1 reassignment is allowed only before trip start and before any stop reaches ARRIVED. Reassignment invalidates active OTPs and blocks the former driver immediately.
Idempotency	Driver/operator POSTs required Idempotency-Key.	All state-changing operational commands require idempotency, including skip, override, resend OTP and reassignment where applicable.
Architecture authority	Diagrams and transition text could be interpreted independently.	Section 14.1 is normative: the transition table, invariants and service transaction rules override illustrative diagrams if any diagram differs.

Contents

- 1. Introduction
- 2. System Context
- 3. Architectural Drivers
- 4. Architecture Overview
- 5. Logical View: Modules
- 6. Data Architecture
- 7. Status Rules (State Machines)
- 8. Key Workflows (Process View)
- 9. API Design
- 10. Security Architecture
- 11. Integration Architecture
- 12. Deployment and Operations
- 13. Cross-cutting Concerns
- 14. Enhancements and Version 1.2 Corrections
- 15. Risks and Open Questions
- Appendix A — Project Folder Structure
- Appendix B — Settings and Default Values

Appendix D — Implementation Build Gates

- Appendix C — Full Permission Matrix

1. Introduction

1.1 Purpose

This document describes the complete technical design of the Neba CS Medical Waste Management Platform. It is the reference for building, reviewing and later maintaining the system. Every module, table, status rule, interface and operational procedure described here is the target the code must match.

1.2 Scope

The platform tracks medical waste from registration at a hospital or pharmacy, through an OTP-verified pickup and GPS-tracked transport, to recorded destruction at one disposal site. It then issues a verifiable Certificate of Disposal, manages contracts and monthly invoices, and gives the EFDA Regulatory & Audit Officer read-only oversight.

In scope	Out of scope (agreed with the client)
Waste registration with one QR label per container	Online payments (Telebirr, CBE Birr, card gateways)
Multi-stop trip scheduling and driver dispatch	Weight discrepancy calculation (weight is recorded only)
OTP-verified handover (Ethio Telecom SMS to Clerk-verified hospital users), in-app fallback, audited override	Disposal photographs
GPS tracking from vehicle trackers, live map, route history	Write access for the EFDA Regulatory & Audit Officer
Disposal receipt, exceptions and destruction record	Native mobile apps (iOS / Play Store)
PDF certificate with public verification page	Hosting setup (arranged by the client)
Contracts, monthly invoices, offline settlement marking	Amharic user interface (English UI; Amharic labels optional)
Dashboards, reports, exports, audit log	

1.3 Audience

- **Developer(s):** the main reference while building each module with Claude Code.
- **Client:** to understand what is being built and approve design decisions and optional enhancements.
- **Future maintainers:** to understand the system after handover.

1.4 Glossary (simple explanations)

Term	Meaning in this project
Architecture	The overall plan of the system: its parts, how they connect, and the rules they follow.
Module	One part of the system with one job, for example "Waste Registration" or "Invoicing".
Service (function)	Server-side code that does the real work of a module, such as saving waste or checking an OTP.
API / endpoint	An address on the server that an app calls to read or change data, e.g. `POST /api/stops/{id}/verify-otp`.
Route Handler / Server Action	The two ways Next.js receives requests: Route Handlers are API addresses; Server Actions are functions called directly by web forms.
Schema / table / migration	The structure of the database. A table stores one kind of record. A migration is a versioned script that changes the structure safely.
Status / state machine	The stage a record is in (e.g. REGISTERED, IN_TRANSIT) and the list of allowed moves between stages.
Transaction	A group of database changes that either all succeed or all fail, so data is never half-saved.
Audit log	A permanent list of who did what and when. Nobody can edit or delete it.

Term	Meaning in this project
OTP	One-Time Password: a 6-digit code sent by SMS to the hospital's registered users; giving it to the driver proves the handover happened.
Verified phone	A phone number the user has proved they own by entering a code Clerk sent to it. Only verified phones receive pickup codes.
Hash	A fingerprint of data. The system stores the fingerprint of OTPs and PDFs, not the original, to detect changes and protect secrets.
Idempotency	If the same request is sent twice (e.g. weak signal, driver taps twice), it only takes effect once.
Outbox	A table of messages waiting to be sent. Messages are saved together with the business change, then sent and retried until delivered.
Geofence	An invisible circle around a place. The system checks whether the truck was inside the hospital's circle when the driver tapped "Arrived".
Adapter	A small piece of code that hides an external service (SMS gateway, tracker) behind a fixed interface, so it can be replaced without touching the rest.
RBAC / facility scope	Role-Based Access Control: what a user may do depends on their role. Facility scope: hospital users only see their own facility.
Seed data	Fictional sample data used for development and demos.
Cron job / scheduler	A task that runs automatically at set times, e.g. monthly invoice generation.
Manifest	The document listing everything a truck carries on a trip.
PITR	Point-In-Time Recovery: restoring the database to how it was at an earlier moment.

1.5 References

- Client system specification and workflow description (30 September 2026) and client answers (October 2026)
- Neba CS System Architecture and Build Blueprint (Next.js, Clerk, Neon)
- CLAUDE.md — project rules for Claude Code (kept consistent with this document)
- EFDA Medicines Waste Management and Disposal Directive (2011); Hazardous Waste Proclamation 1090/2018; Personal Data Protection Proclamation 1321/2024; MoH Healthcare Waste Management Manual (2021)
- OWASP Top 10 and Application Security Verification Standard (ASVS)

2. System Context

The context view shows the platform as one box, the people who use it and the external systems it depends on.

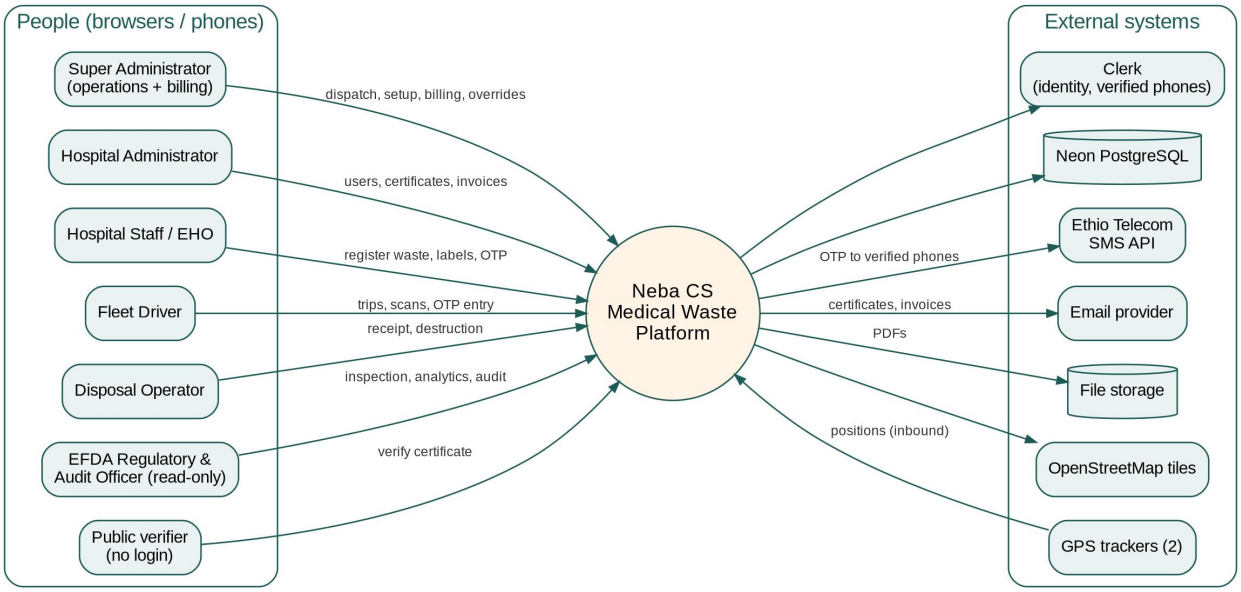


Figure 1 — System context

2.1 Actors and roles

Role (code)	Who	Main responsibilities	Area
Super Administrator (`super_admin`)	Company operations, dispatch and billing team	System oversight; facilities, users, fleet, trackers, settings; build and change trips; fleet radar (live map); OTP override; revoke certificates; **contracts, monthly invoices (ETB) and settlement**; alerts	/admin
Hospital Administrator (`hospital_admin`)	Person responsible for one facility	Everything Hospital Staff can do, plus: manage own facility's users and who receives pickup codes; certificates; invoice totals (ETB)	/hospital
Hospital Staff / EHO (`hospital_staff`)	Staff or Environmental Health Officer at a hospital or pharmacy	Register waste, label containers, follow pickups, **receive the pickup OTP** on their verified phone, confirm handover in-app as fallback, download certificates	/hospital
Fleet Driver (`driver`)	One of two drivers	Mobile-first route and stop sequence, arrival, container scans, OTP entry	/driver (mobile)
Disposal Operator (`disposal_operator`)	Staff at the disposal site	Inbound truck reception, container scans, incinerator queue, exceptions, destruction records	/disposal (mobile/tablet)
EFDA Regulatory & Audit Officer (`efda_officer`)	Regulator and compliance auditor	**Read-only:** compliance inspection, volume analytics, route replay, certificates, immutable audit ledger and its integrity check	/regulator
Public verifier (no login)	Inspector or anyone holding a certificate	Checks a certificate through its QR code	/verify/{token}

2.2 External systems

System	Used for	Direction	If it is unavailable

System	Used for	Direction	If it is unavailable
Clerk	Sign-in, sessions, password reset, **phone number verification** for hospital users	Platform → Clerk	Nobody can sign in; data is safe. Status shown on login page.
Neon PostgreSQL	All business data	Platform → Neon	System unavailable; health check alerts the admin.
Ethio Telecom SMS API	Pickup OTP to verified hospital users; short notices	Platform → gateway	Signed-in hospital users can confirm the handover in-app; outbox retries; Super Admin override.
Email provider	OTP backup, certificates, invoices, alerts	Platform → provider	Outbox retries; messages are never lost.
GPS trackers (2)	Vehicle positions	Tracker → platform	Map shows "last seen"; alert if silent during a trip; pickups continue.
OpenStreetMap tiles	Map background	Browser → tiles	Map shows markers without background; nothing else affected.
Object storage	Certificate, invoice and manifest PDFs	Platform → storage	PDF generation retried; records are already saved.

3. Architectural Drivers

Architectural drivers are the requirements that shape the design most. They are listed here so every design decision can be traced back to one of them.

3.1 Key functional requirements

ID	Requirement
FR-01	Hospital users register waste with category, container count (≥ 1) and weight (> 0 kg); the system creates a Waste ID and one QR label per container.
FR-02	The Super Administrator groups pickups from several facilities into one trip with an ordered list of stops, one vehicle and one driver.
FR-03	A pickup cannot be completed without a valid OTP sent by the Ethio Telecom SMS API to the facility's hospital users with Clerk-verified phones, or an in-app confirmation by a signed-in user of that facility, or an audited Super Admin override with a reason.
FR-04	Vehicle positions are recorded from GPS trackers and shown live and as route history to the Super Administrator and the EFDA Regulatory & Audit Officer.
FR-05	The disposal operator scans every arriving container, records missing or refused containers, and records destruction (operator, time, method).
FR-06	Recording destruction locks the record and generates a PDF Certificate of Disposal with a verification QR code.
FR-07	Anyone with a certificate can verify it publicly without signing in.
FR-08	The Super Administrator generates monthly invoices from active contracts and marks them settled when paid outside the system.
FR-09	The EFDA Regulatory & Audit Officer can see all data and verify the audit ledger but change nothing.
FR-10	Every change is recorded in a permanent audit log.
FR-11	Each role has a dashboard; reports can be exported to PDF and Excel.

3.2 Quality attributes (non-functional requirements)

ID	Quality	Target (measurable)
NFR-01	Integrity	No status can be skipped or reversed outside the rules; zero ways to edit a destroyed record or audit row, verified by tests.
NFR-02	Security	Every endpoint checks role and facility scope; OWASP Top 10 reviewed; permission matrix covered 100% by automated tests.
NFR-03	Performance	Driver and operator actions respond in under 1 s (p95) on 3G; dashboards load in under 2.5 s (p95) with 120 facilities and 2 years of data.
NFR-04	Reliability	No OTP, certificate or invoice message lost: every message stored before sending and retried up to the configured limit.
NFR-05	Availability	99% during operating hours (06:00–20:00 EAT); planned maintenance outside these hours.
NFR-06	Recoverability	Data loss at most 24 hours (RPO), better with Neon point-in-time recovery; service restored within 8 hours (RTO); restore tested monthly.
NFR-07	Usability	Driver and operator screens usable on a 5-inch Android phone: touch targets ≥ 48 px, one main action per screen, clear error messages.
NFR-08	Scalability	Handles 500 users, 120+ facilities, 2–10 vehicles and 1 GPS point per 10 s per vehicle without design changes.
NFR-09	Maintainability	Each module in its own folder with tests; external services behind adapters; documentation updated with every module.

ID	Quality	Target (measurable)
NFR-10	Privacy	Only necessary personal data collected; vehicle location shown only during active trips; public pages show minimum data.

3.3 Constraints

- Technology fixed by the client blueprint: Next.js, Clerk, Neon PostgreSQL. Maps: OpenStreetMap for the demo.
- Hosting is chosen and paid by the client; the code must stay hosting-neutral (configuration through environment variables only).
- GPS comes from hardware trackers; the vendor and data format are not yet known.
- Driver and operator use a mobile web app in the browser; no native app.
- English user interface; Ethiopian time zone (Africa/Addis_Ababa) for display and monthly periods.
- Small team (solo developer with Claude Code) and fixed price: the design must stay simple and well-tested.

3.4 Assumptions

- The client's company is permitted by EFDA to issue the Certificate of Disposal (client's statement; permission letter requested).
- Each facility has at least one active hospital user (Staff/EHO or Admin) with a phone number verified through Clerk.
- Clerk can deliver its phone-verification SMS to Ethiopian (+251) numbers — to be tested in the first build.
- Hospitals can print labels (A4 or label printer); otherwise labels can be printed by the company.
- The business starts with a pilot of a few facilities before growing to 120+.

4. Architecture Overview

4.1 Architectural style: modular monolith

The system is **one Next.js application** containing all modules, deployed as one unit. Inside, each module has its own folder, its own service functions and its own tables. Modules talk to each other only by calling each other's service functions — never by reading another module's tables directly.

Why not microservices? With one developer, 2 vehicles and about 500 users, separately deployed services would add networking, deployment and debugging work with no benefit. A modular monolith keeps the clean boundaries that make modules testable and replaceable, while staying simple to run. If one part ever needs to scale separately (for example GPS ingest), its module boundary makes it easy to move out.

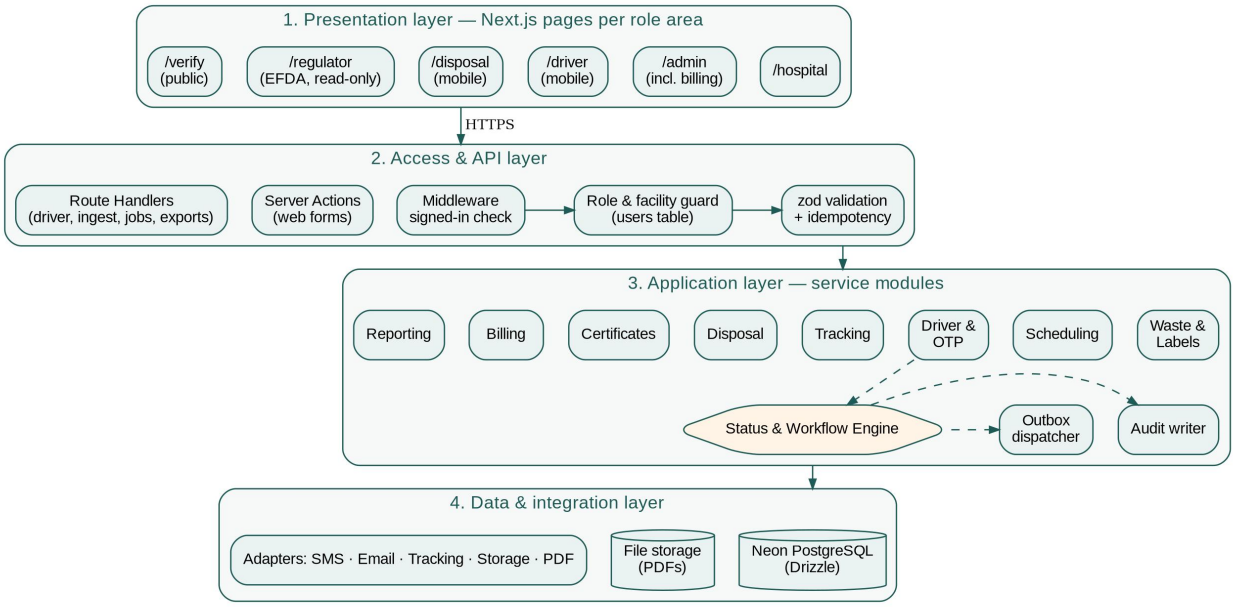


Figure 2 — Layered architecture

4.2 The four layers

Layer	What it contains	Rules
1. Presentation	Next.js pages grouped by role area; shared UI components (shadcn/ui), maps (Leaflet), charts (Recharts), QR scanner	Never touches the database. Server Components for reading; Client Components only for interaction (forms, scanner, map).
2. Access & API	Middleware (signed-in check), role and facility guard, zod validation, idempotency check; Server Actions for web forms; Route Handlers for driver actions, tracker ingest, scheduled jobs, exports, public verification	Every request is authenticated (or explicitly public), authorized from the database, and validated before any service runs.
3. Application	Service modules in `src/server/services/`, the Status & Workflow Engine, audit writer, outbox dispatcher	All business rules live here. Status changes only through the Workflow Engine, inside a transaction that also writes the audit row.
4. Data & integration	Neon PostgreSQL through Drizzle; object storage; adapters for SMS, email, trackers, storage and PDF rendering	External services are only reached through adapters, so they can be swapped or mocked in tests.

4.3 Technology stack

Concern	Technology	Notes

Concern	Technology	Notes
Framework	Next.js (App Router), TypeScript strict	UI and API in one codebase; follow the installed version's conventions
UI	Tailwind CSS, shadcn/ui, Recharts, TanStack Table, react-hook-form + zod	Mobile-first for /driver and /disposal
Authentication	Clerk (identity only)	Roles and facility live in the database; all Clerk code in `src/server/auth/`
Database	Neon PostgreSQL + Drizzle ORM + Drizzle migrations	Pooled connection for requests; direct connection for migrations
Maps	Leaflet + react-leaflet + OpenStreetMap tiles	Client-only components; tile URL from environment (replaceable for production)
QR	Server-side QR generation; browser camera scanner	QR content is an opaque code — no personal data
Documents	Server-side PDF rendering; Excel export library	Labels, manifests, certificates, invoices, reports
Messaging	Ethio Telecom SMS gateway; email provider	Behind adapters; sent through the outbox
Testing	Vitest, Playwright	Unit, integration (test database branch), end-to-end
Tooling	pnpm, ESLint, Prettier, GitHub Actions (or similar CI)	CI runs lint, typecheck, tests and build on every push

4.4 Key design decisions

#	Decision	Reason	Alternative rejected
AD-01	Modular monolith in Next.js	One developer; simple deployment; clean module boundaries	Microservices — too much operational work
AD-02	Database is the source of truth for roles; Clerk only for identity	One place to check permissions; no mismatch between systems; Clerk replaceable	Roles in Clerk metadata — can drift from data
AD-03	Central Status & Workflow Engine	Status rules in one place; impossible to skip steps; every move audited	Status updates spread across modules
AD-04	One QR code per container	Missing or refused containers can be identified exactly	One QR per registration — cannot tell which box is missing
AD-05	Transactional outbox for SMS and email	Messages never lost; retries without blocking the user	Sending directly inside the request
AD-06	Idempotency keys on driver and operator actions	Weak mobile signal causes repeated requests; each action must happen once	Hoping users do not double-tap
AD-07	GPS from trackers through a TrackingProvider adapter + simulator	Vendor unknown; demo still possible; no rework later	Phone browser location — stops with screen off
AD-08	OTP stored as hash, single use, limited attempts and resends	Codes cannot be read from the database or guessed	Plain codes in the database
AD-09	Certificate integrity by SHA-256 + public verification page	Simple, strong, understandable; cryptographic PDF signature optional later	Certified digital signature from the start — high cost
AD-10	Append-only audit log with hash chain	Tampering is blocked by the database and detectable if attempted	Normal editable log table
AD-11	Money as integer santim; time stored in UTC, shown in EAT	No rounding errors; correct monthly periods	Decimals / local time storage

#	Decision	Reason	Alternative rejected
AD-12	Six roles: finance merged into Super Admin, audit merged into EFDA officer	Matches the client's small team; fewer accounts and screens	8 separate roles
AD-13	OTP sent to Clerk-verified hospital users via Ethio Telecom; in-app confirmation as fallback	Phone numbers are proven real; no unmanaged contact data; every handover tied to a known account	Separate authorized-contact phone/email on the facility

5. Logical View: Modules

The system is divided into **20 modules** built in 7 phases. Each module owns specific tables and exposes service functions. The arrows in Figure 3 show "is needed by": a module can only be built and tested once the modules pointing to it exist.

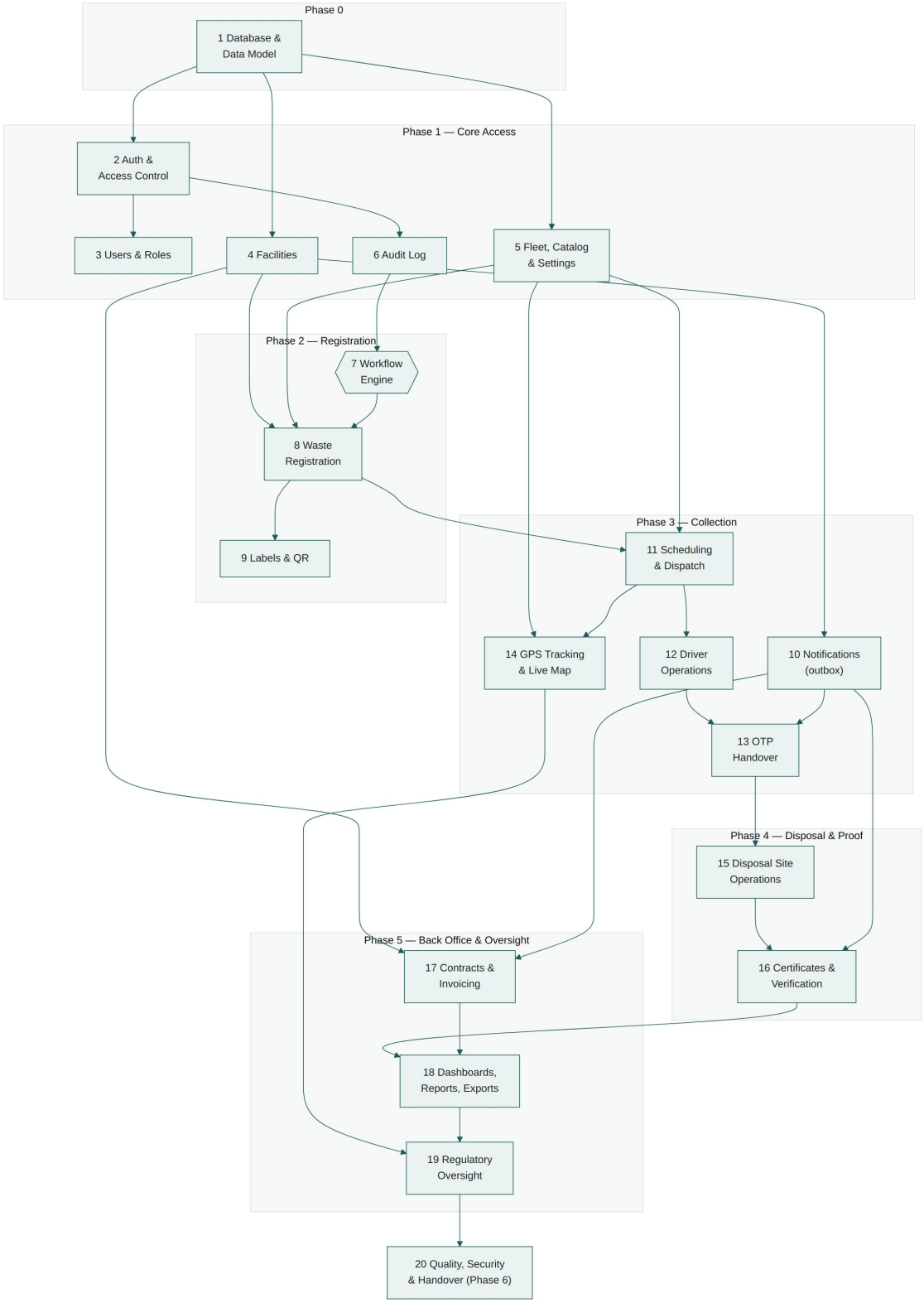


Figure 3 — Modules and their dependencies by build phase

5.1 Module catalogue

#	Module	Responsibility	Owns tables	Main service functions
1	Database & Data Model	Schema, constraints, migrations, seed data	All (schema owner)	`db`, migrations, `seed`
2	Auth & Access Control	Session → user, role and facility checks, waiting-for-access page	— (reads users)	`getCurrentUser`, `requireRole`, `requireFacilityScope`
3	Users & Roles	Invite, activate/deactivate, assign role and facility, OTP-recipient flag; sync verified phone from Clerk	users	`inviteUser`, `assignRole`, `setOtpRecipient`, `syncFromClerk`
4	Facilities	Facility records, map location, status, readiness (has OTP recipients)	facilities	`createFacility`, `updateFacility`, `listFacilities`, `getOtpRecipients`
5	Fleet, Catalog & Settings	Vehicles, drivers, trackers, licenses, waste categories, destruction methods, settings	vehicles, drivers, tracker_devices, licenses, waste_categories, destruction_methods, settings	`assignTracker`, `checkLicenses`, `getSetting`
6	Audit Log	Append-only record with hash chain	audit_logs	`audit.record(event, tx)`
7	Status & Workflow Engine	Allowed transitions, guards, atomic status change + audit + event	— (writes status via owners)	`transition(entity, id, action, ctx)`
8	Waste Registration	Register and cancel waste	waste_records	`registerWaste`, `cancelWaste`
9	Labels & QR	Container codes, label PDFs, QR resolution	containers	`generateLabels`, `resolveContainer`
10	Notifications	Templates, outbox, SMS/email adapters, retries	outbox_messages	`enqueue(msg, tx)`, `dispatchPending`
11	Scheduling & Dispatch	Trips, ordered stops, assignment, reassignment, trip manifest	trips, trip_stops, trip_stop_waste	`createTrip`, `reorderStops`, `assignTrip`, `cancelTrip`, `manifestPdf`
12	Driver Operations	Driver job list, start trip, arrival, container scans	handovers	getJobs, startTrip, arrive, scanContainer, skipStop
13	OTP Handover	OTP to facility users' verified phones (Ethio Telecom), resend, verify, lock, in-app confirmation, override	otp_codes	issueOtp, verifyOtp, resendOtp, confirmInApp, overrideStop, cancelActiveOtps
14	GPS Tracking & Live Map	Tracker ingest, trip matching, live positions, history, geofence distance	gps_events	`ingest`, `livePositions`, `tripTrack`, `distanceToFacility`
15	Disposal Site Operations	Receipt scans, missing/refused, destruction, locking	disposal_records	`receiveContainer`, `markException`, `recordDestruction`
16	Certificates & Verification	PDF, hash, verify token, revoke	certificates	createPending, generatePdf, retryGeneration, verify, revoke

#	Module	Responsibility	Owns tables	Main service functions
17	Contracts & Invoicing	Contracts, monthly drafts, issue, settle, cancel (Super Admin)	contracts, invoices	`generateMonthly`, `issueInvoice`, `settleOffline`
18	Dashboards, Reports & Exports	Role dashboards, reports, PDF/Excel exports	daily_waste_stats (optional E10)	area queries, `exportReport`
19	Regulatory Oversight	Read-only views for the EFDA Regulatory & Audit Officer, audit ledger and integrity check	—	regulator queries, `verifyAuditChain`
20	Quality, Security & Handover	Tests, security review, pilot, deployment, documentation	—	—

5.2 Module interaction rules

- A module reads and writes **only its own tables**. To use another module's data it calls that module's service function.
- Status columns are changed only by the Workflow Engine (Module 7), which checks the transition table (Section 7), runs the guard, writes the audit row and saves — all in one transaction. Operational commands may create evidence rows (for example a container scan), but they may not bypass the Workflow Engine to declare a business state complete.
- Anything that must not be lost (SMS, email) is written to the outbox **in the same transaction** as the business change (Module 10).
- Every service function begins with an access check (requireRole, and requireFacilityScope for hospital roles). UI checks are only for convenience; the server check is the real one. State-changing services also enforce idempotency and execute the business change, audit row and required outbox messages in one transaction.
- Read-only modules (18, 19) use dedicated query functions with SQL aggregates and never call write services.

5.3 Internal events

After a transaction commits, the Workflow Engine emits an in-process event. Events are used for side effects that can safely be repeated; messages that must arrive go through the outbox instead.

Event	Emitted when	Consumers
`waste.registered` / `waste.cancelled`	Hospital registers or cancels waste	Notifications (optional notice to Super Admin)
`trip.assigned` / `trip.reassigned`	Super Admin assigns or changes vehicle/driver	Notifications (email to driver)
`stop.arrived`	Driver taps Arrived	OTP Handover (SMS code to facility users), Tracking (geofence check), /hospital (shows "truck at the door")
`stop.collected` / `stop.overridden`	OTP verified / override used	Notifications (receipt email to facility); override also alerts admins
`container.exception`	Container marked missing or refused	Notifications (alert to super admin and facility)
`waste.disposed`	Destruction recorded	Certificates (issue certificate)
`certificate.issued` / `certificate.revoked`	Certificate created or revoked	Notifications (email to hospital admin)
`invoice.issued`	Super Admin issues an invoice	Notifications (email to hospital admin)

Event	Emitted when	Consumers
`license.expiring`	Daily license check finds expiry within warning days	Notifications (alert to super admin)
`tracker.silent`	No GPS point for 15 min during an active trip	Dashboards alert, notification to Super Admin

6. Data Architecture

All business data lives in one Neon PostgreSQL database. The schema is created by Module 1 and changed only through versioned migrations. Figure 4 (next page) shows the main relationships.

6.1 Data conventions

Topic	Convention
Primary keys	UUID (time-ordered v7) on every table: `id`. Never shown to users.
Human codes	Waste ID `WR-2610-00042` (year-month-sequence); container `WR-2610-00042-C03`; trip `TR-261004-01`; certificate `CD-2026-00017`; invoice `INV-2026-10-0031`. Unique and never reused.
QR content	Only the container code or the verification URL — never names, phone numbers or patient data.
Timestamps	`timestamptz`, stored in UTC; displayed and grouped by month in Africa/Addis_Ababa. All tables have `created_at`, `updated_at`; most have `created_by`.
Money	Integer santim (`bigint`, ETB × 100). VAT rate stored on each invoice at creation time.
Statuses	PostgreSQL enums; changed only by the Workflow Engine.
Deletion	No hard deletes of business records. Use `active = false` or a CANCELLED/REVOKED status with a reason.
Personal data	Names, emails and verified phone numbers of users only. No patient data is ever stored.

6.2 Table dictionary

Table	Key columns	Rules and notes
facilities	code, name, type (hospital/pharmacy), region, address, lat, lng, status	Pickups can be scheduled only if the facility has at least one OTP recipient
users	clerk_user_id (unique), role, facility_id (nullable), full_name, email, phone_e164, phone_verified, receives_pickup_otp, active	Phone and verification synced from Clerk; facility_id required for hospital roles, forbidden for others (CHECK); receives_pickup_otp only for hospital roles
vehicles	plate_no (unique), capacity_kg, status	2 vehicles at start
drivers	user_id (unique), license_no, default_vehicle_id	One driver per user
tracker_devices	device_id (unique), vehicle_id (unique), token_hash, last_seen_at, active	Device token stored only as hash
licenses	subject_type (vehicle/driver/facility/site), subject_id, kind, number, issued_on, expires_on	Expired license blocks trip assignment (E5)
waste_categories	code, name, colour_code, active	Matches MoH colour coding; text always shown with colour
destruction_methods	code, name, active	Chosen by the operator when recording destruction
waste_records	waste_code, facility_id, category_id, container_count, weight_kg, status, registered_by, cancel_reason	CHECK container_count ≥ 1, weight_kg > 0. Status includes DISPOSED_WITH_EXCEPTION for a locked record where some containers were destroyed and others formally MISSING/REFUSED.

Table	Key columns	Rules and notes
containers	container_code, waste_record_id, seq_no, status, exception_reason	Unique (waste_record_id, seq_no); count equals container_count. Statuses: LABELLED, SCANNED_AT_PICKUP, COLLECTED, RECEIVED, MISSING, REFUSED, DESTROYED.
trips	trip_code, vehicle_id, driver_id, planned_date, status, started_at, completed_at, cancel_reason	One active trip per vehicle and per driver (partial unique index)
trip_stops	trip_id, facility_id, priority_order, status, collection_method (OTP / IN_APP / OVERRIDE), confirmed_by, arrived_at, completed_at, arrival_distance_m, geofence_ok, override_reason, skip_reason	Unique (trip_id, priority_order); collection_method is set only when completion succeeds; completion requires all expected containers accounted for.
trip_stop_waste	trip_stop_id, waste_record_id	A waste record can be on only one non-cancelled stop
otp_codes	trip_stop_id, code_hash, recipient_count, expires_at, attempts, status, verified_at, cancelled_at	Never store the plain code. Statuses: ISSUED, VERIFIED, EXPIRED, LOCKED, CANCELLED. Active codes are cancelled when the stop is skipped/cancelled or a permitted pre-start reassignment occurs.
handovers	trip_stop_id, container_id, otp_id, driver_id, scanned_at, status, idempotency_key	Unique (trip_stop_id, container_id). Statuses: SCANNED, CANCELLED. Scan evidence is not final collection; it is retained for audit if the stop is skipped/cancelled.
gps_events	device_id, vehicle_id, trip_id (nullable), lat, lng, speed_kmh, heading, recorded_at, received_at	Unique (device_id, recorded_at) for duplicate-safe ingest
disposal_records	waste_record_id (unique), operator_id, received_at, method_id, destroyed_at, locked	Locked rows cannot be updated (trigger)
certificates	certificate_no, disposal_record_id, file_key, sha256, verify_token (unique), status, issued_at, revoked_reason, generation_attempts, last_error	Statuses: PENDING, ISSUED, FAILED, REVOKED. Destruction is independent and already locked before certificate generation. Reissue creates a new row; old one REVOKED.
contracts	facility_id, start_date, end_date, monthly_fee_santim, terms, status	Only one ACTIVE contract per facility per period
invoices	invoice_no, contract_id, facility_id, period_start, period_end, subtotal, vat_rate, vat_amount, total, status, issued_at, settled_at, settlement_ref	Unique (contract_id, period_start) — no double billing
outbox_messages	channel (sms/email), recipient, template, payload, status, attempts, next_attempt_at, last_error, provider_ref	Created in the same transaction as the business change
idempotency_keys	key, user_id, route, response_status, response_body, created_at	Kept 24 hours; replay returns the stored response
audit_logs	actor_user_id, role, action, entity_type, entity_id, before, after, ip, request_id, prev_hash, hash, created_at	INSERT only; UPDATE/DELETE blocked by trigger; hash chain (E8)
settings	key, value, updated_by	Defaults in Appendix B

6.3 Important indexes

- `waste_records (facility_id, status, created_at)` — hospital lists and overdue checks
- `trips (planned_date, status)` and `trip_stops (trip_id, priority_order)` — dispatch and driver screens
- `gps_events (vehicle_id, recorded_at DESC)` — live position and history
- `invoices (facility_id, status)` and `contracts (facility_id, status)` — finance views
- `audit_logs (created_at DESC)`, `(entity_type, entity_id)` — audit viewer
- `outbox_messages (status, next_attempt_at)` — Super Admin job

6.4 Data retention (proposed — confirm with the client and EFDA)

Data	Proposed retention
Waste records, containers, disposal records, certificates, invoices, audit log	At least 10 years (legal evidence)
GPS points	24 months in full; then only daily summaries (distance, stops)
OTP records	12 months
Outbox messages and idempotency keys	90 days / 24 hours
Deactivated users	Kept (needed for audit history); personal fields can be minimized on request

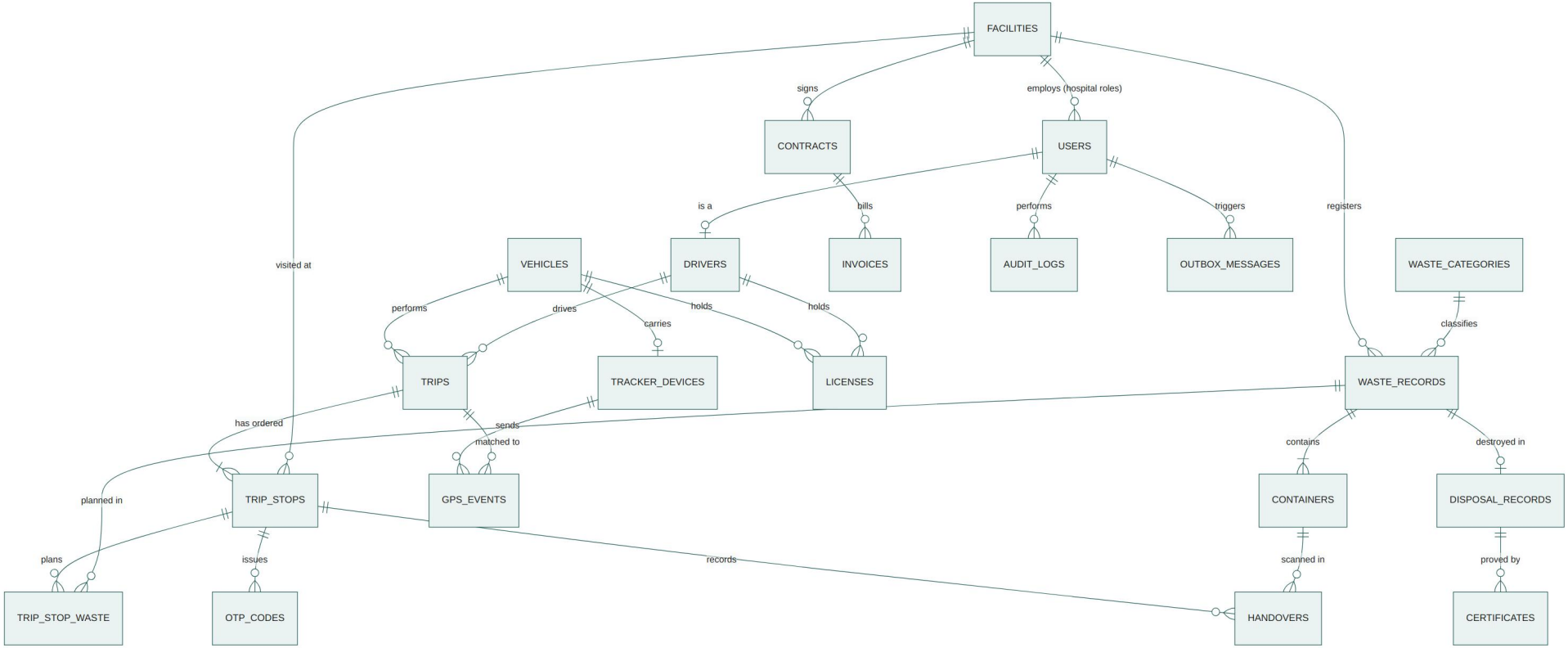


Figure 4 — Entity-relationship diagram (main tables)

7. Status Rules (State Machines)

Each tracked object has a fixed set of statuses and allowed moves. The Workflow Engine refuses any move that is not in these tables (HTTP 409 INVALID_TRANSITION). Normal business progress is forward; tentative pickup evidence may be reset from SCANNED_AT_PICKUP to LABELLED only when a stop has not completed and is skipped/cancelled. Locked records cannot change.

7.1 Waste record



Figure 5 — Waste record statuses (v1.2 normative)

7.2 Container

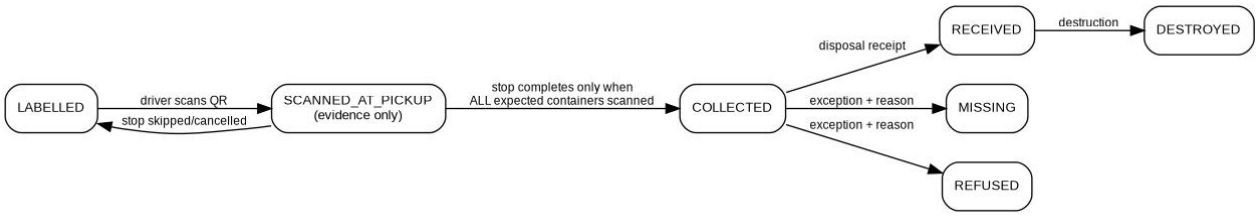


Figure 6 — Container statuses (v1.2 normative)

7.3 Trip and trip stop

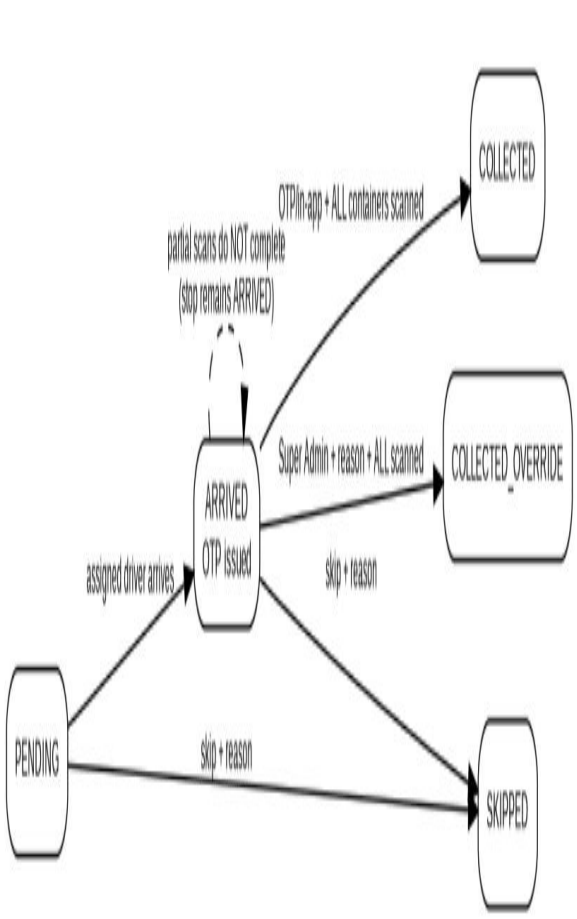


Figure 7 — Trip and stop statuses (v1.2 normative)

7.4 Invoice

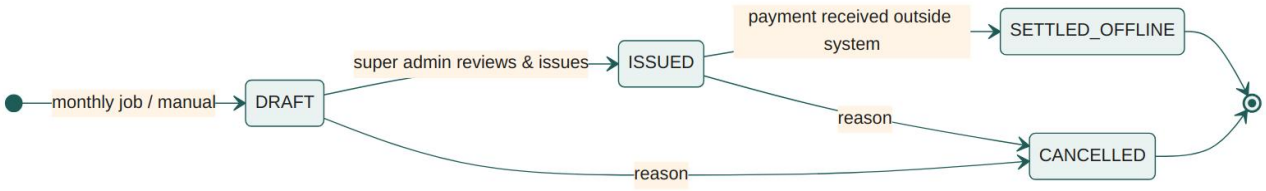


Figure 8 — Invoice statuses

7.5 Complete transition table

Entity	From → To	Action / who	Guard (must be true)	Side effects
Waste	SCHEDULED → REGISTERED	stop skipped or trip cancelled / system	Stop skipped/cancelled before successful pickup	Waiting list restored; audit; active OTPs cancelled
Waste	REGISTERED/SCHEDULED → CANCELLED	cancel / hospital roles (own), super_admin	Reason; no container is COLLECTED	Labels invalid; audit
Waste	SCHEDULED → IN_TRANSIT	complete stop / system	Stop is COLLECTED or COLLECTED_OVERRIDE AND every expected container is COLLECTED	Waste moves atomically with successful stop completion
Waste	IN_TRANSIT → RECEIVED	complete receipt / disposal_operator	Every container is accounted for: RECEIVED, MISSING or REFUSED	Exception alert if any MISSING/REFUSED
Waste	RECEIVED → DISPOSED	complete destruction / disposal_operator	Every container is DESTROYED	Disposal locked; certificate job created
Waste	RECEIVED → DISPOSED_WITH_EXCEPTION	destruction with exceptions / disposal_operator	At least one DESTROYED and every remaining container formally MISSING/REFUSED with reason	Disposal locked; certificate covers destroyed containers and lists exceptions
Container	LABELLED → SCANNED_AT_PICKUP	scan QR / driver	Belongs to a waste record on this ARRIVED stop; not already scanned	Handover evidence; pickup not yet complete
Container	SCANNED_AT_PICKUP → COLLECTED	stop completion / system	All expected containers for the stop are scanned and completion succeeds	All containers changed atomically
Container	SCANNED_AT_PICKUP → LABELLED	stop skipped/cancelled / system	Stop has not completed	Scan evidence retained as CANCELLED for audit
Container	COLLECTED → RECEIVED	receipt scan / disposal_operator	Belongs to this waste and not already received	Receipt recorded
Container	COLLECTED → MISSING / REFUSED	exception / disposal_operator	Reason required; exception confirmed	Exception alert

Entity	From → To	Action / who	Guard (must be true)	Side effects
			at disposal site	
Container	RECEIVED → DESTROYED	destruction / system	Waste destruction includes this container	Container locked as destroyed
Stop	ARRIVED → COLLECTED	verify OTP / driver	OTP VERIFIED AND unique scan count equals expected container count AND every expected container is SCANNED_AT_PICKUP	collection_method=OTP; all containers COLLECTED atomically
Stop	ARRIVED → COLLECTED	confirm in-app / hospital user (same facility)	Facility matches; unique scan count equals expected count; every expected container scanned	collection_method=IN_APP; all containers COLLECTED atomically; active OTPs CANCELLED
Stop	ARRIVED → COLLECTED_OVERRIDE	override / super_admin	Written reason AND every expected container scanned	collection_method=OVERRIDE; all containers COLLECTED atomically; alert visible to EFDA
Stop	PENDING/ARRIVED → SKIPPED	skip / driver, super_admin	Reason; stop has not completed	Active OTPs CANCELLED; tentative scans reset to LABELLED; waste returns to REGISTERED
Trip	PLANNED → IN_PROGRESS	start / driver (assigned)	Vehicle and driver licenses valid; no other active trip	GPS matching starts
Trip	reassign (no status change)	reassign / super_admin	PLANNED only; no stop ARRIVED; new vehicle/driver valid	Former driver blocked; active OTPs cancelled; audit; new driver notified
Trip	PLANNED → CANCELLED	cancel / super_admin	Reason; trip not started	Waste returns to REGISTERED
Trip	IN_PROGRESS → CANCELLED	cancel / super_admin	Reason; no stop ARRIVED and no container collected	Waste returns to REGISTERED
OTP	ISSUED → VERIFIED / EXPIRED / LOCKED / CANCELLED	verify/lifecycle / system	Correct code / expiry / max attempts / stop cancelled-skipped-reassigned	Single-use; resend only within cooldown and per-stop limit
Certificate	— → PENDING → ISSUED	certificate job / system	Locked disposal exists; PDF/hash succeeds	Only ISSUED is publicly valid
Certificate	PENDING/FAILED → FAILED / ISSUED	retry job / system	Generation fails or succeeds	No rollback of destruction
Certificate	ISSUED → REVOKED	revoke / super_admin	Revocation reason	Verify page shows REVOKED; history retained

8. Key Workflows (Process View)

Each workflow shows the exact sequence of calls between the user, the API, the services and the database, followed by how failures are handled.

8.1 Waste registration and labels

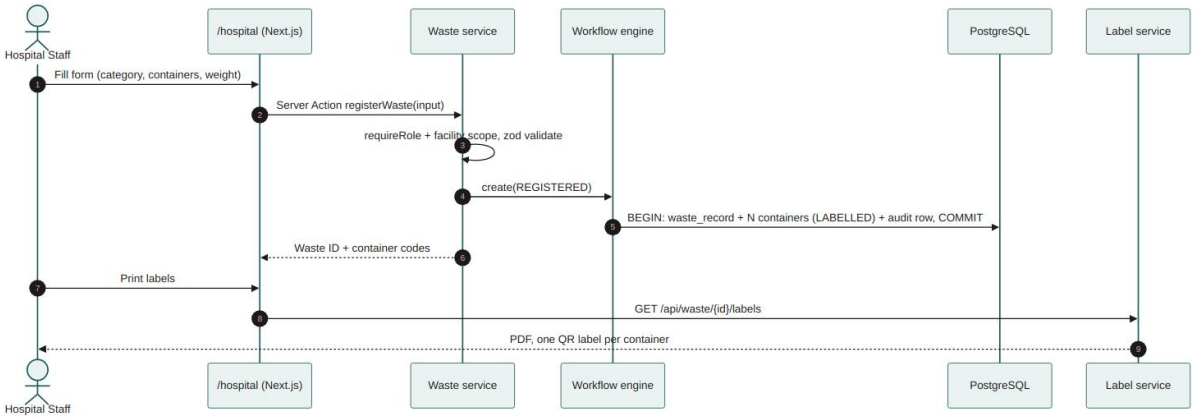


Figure 9 — Registration sequence

- **Invalid input** (0 containers, weight ≤ 0, missing category): rejected by zod in the browser and again on the server (HTTP 422).
- **Printing fails:** labels can be reprinted any time from the record; reprints are audited, codes stay the same.

8.2 Trip scheduling and dispatch

Step	What happens
1	Super Admin opens the waiting list and map: REGISTERED waste grouped by facility, oldest and overdue first.
2	Super Admin selects facilities, sets stop order (manual, with a "nearest next" suggestion), date, vehicle and driver.
3	System checks: vehicle and driver have valid licenses (E5), no other active trip, every facility has at least one OTP recipient (hospital user with a Clerk-verified phone).
4	In one transaction: trip (PLANNED), stops (PENDING), waste → SCHEDULED, audit rows, outbox email to driver.
5	Trip appears on the driver's /driver page; the manifest PDF (E4) can be printed for the vehicle.

8.3 OTP-verified handover (the core rule)

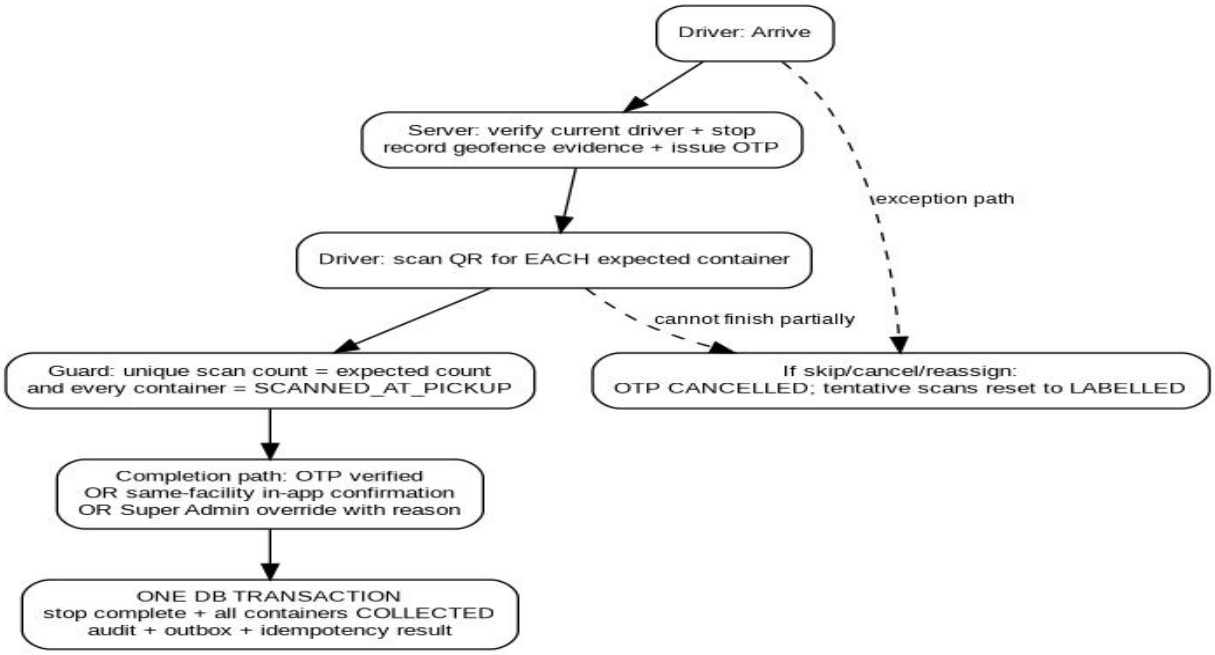


Figure 10 — Handover sequence with failure paths (v1.2 normative)

Situation	System behaviour
Driver taps Arrived twice / weak signal	Same Idempotency-Key → second request returns the first response; only one OTP.
Truck is far from the facility	Arrival still allowed; `geofence_ok = false` and distance stored; shown to Super Admin and EFDA (E3).
Wrong code	Attempt counted; message shows attempts left; after the maximum the OTP is LOCKED.
Code expired or not received	Driver requests a new code after the cooldown; at most `otp_max_per_stop` codes; then only override.
SMS gateway down or SMS not received	Signed-in hospital users see "truck at the door" on /hospital and can confirm the handover in-app (IN_APP); outbox retries SMS; Super Admin override as last resort.
Facility has no user with a verified phone	Pickup cannot be scheduled; the facility shows "not ready" on the admin dashboard until a user verifies a phone in Clerk.
Several users receive the code	Any of them can give it; the first correct entry completes the stop; the code is then VERIFIED and unusable.
Override	Only super_admin, written reason required, stop becomes COLLECTED_OVERRIDE, admins alerted, visible to EFDA.
Scan only part of a waste record	The stop cannot be completed. Scanned containers remain SCANNED_AT_PICKUP, not COLLECTED. Driver must scan every expected container or skip. On skip, tentative scans reset to LABELLED and evidence is retained as CANCELLED.
Driver acts after reassignment	Server checks current assigned driver; old driver gets 403/DRIVER_NOT_ASSIGNED. Active OTPs from the reassignment are CANCELLED.
Stop skipped after OTP issued	All active OTPs for that stop become CANCELLED; the old code can never complete a later stop.
Certificate PDF generation fails	Disposal remains locked. Certificate is PENDING/FAILED with error metadata; retry job attempts generation; destruction is never rolled back.
Disposal receives only some containers	Waste cannot leave IN_TRANSIT until every expected container is RECEIVED, MISSING or REFUSED. No certificate is issued for an

Situation	System behaviour
	unaccounted container.
Duplicate/replayed tracker point	Duplicate (device_id, recorded_at) is ignored. Points outside the accepted clock-skew/age window are rejected and logged.

8.4 GPS ingest and live map

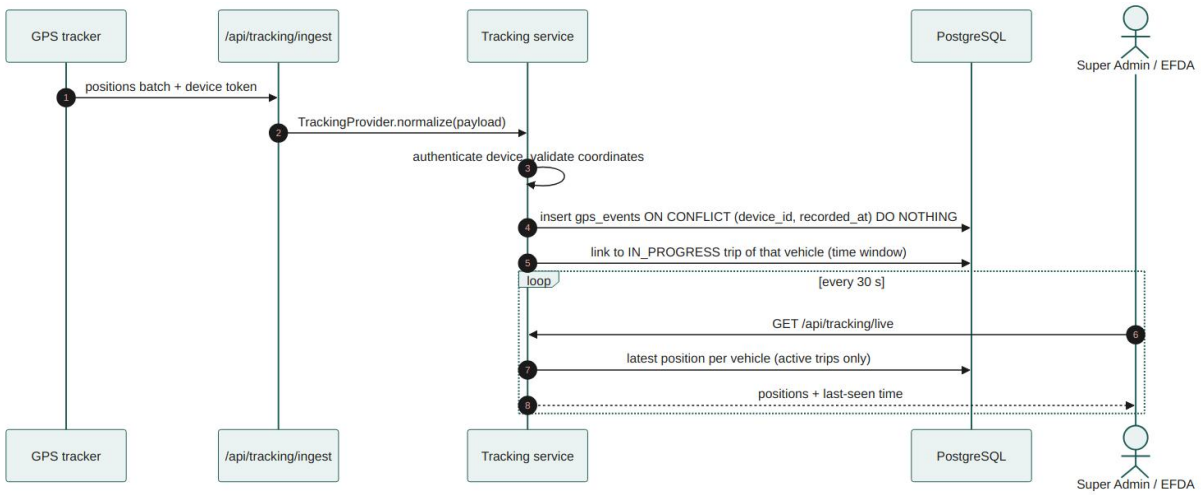


Figure 11 — GPS ingest and live map

- **Out-of-order or duplicate points:** stored by `recorded_at`; duplicates ignored by the unique key.
- **Tracker silent for 15 minutes during an active trip:** `tracker.silent` alert on the Super Admin dashboard; map shows "last seen".
- **Privacy:** maps show positions only for IN_PROGRESS trips; points outside trips are stored but not displayed.

8.5 Disposal and certificate

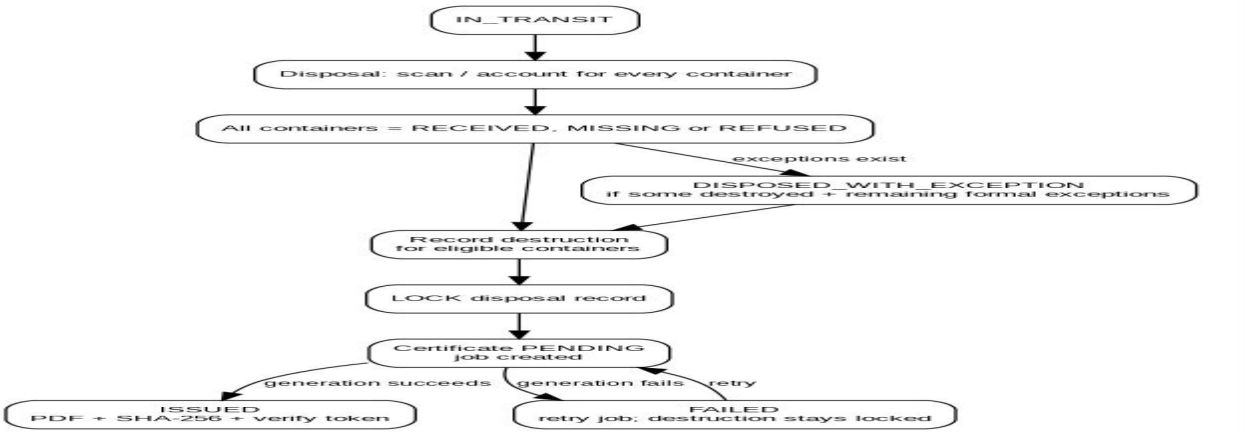


Figure 12 — Disposal and certificate (v1.2 normative)

- Every expected container must be accounted for before the waste leaves IN_TRANSIT. Missing/refused containers require a reason and alert; a certificate covers only containers actually destroyed and lists the exceptions.
- PDF generation fails: destruction is already committed and locked; certificate remains PENDING/FAILED and is retried by a job; dashboard shows the certificate generation state. Destruction is never rolled back.

8.6 Monthly invoicing

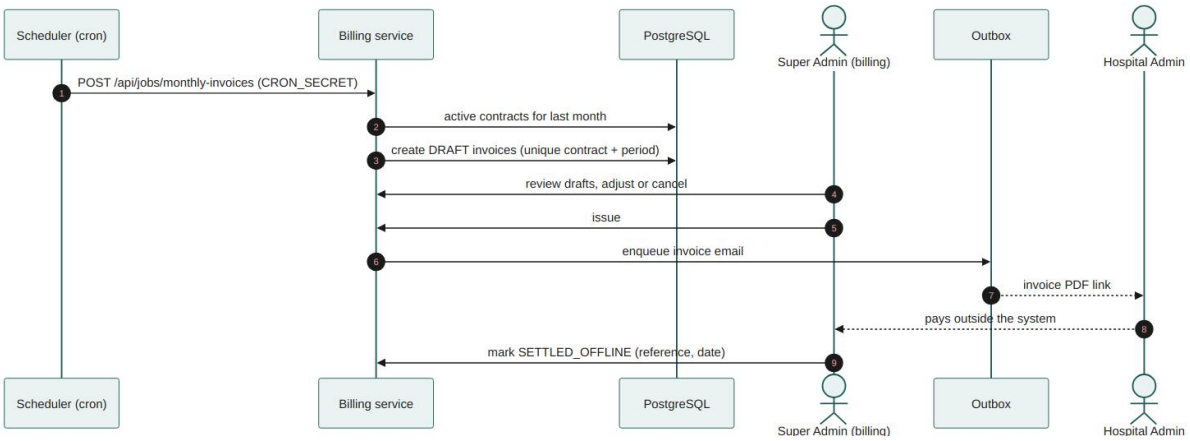


Figure 13 — Monthly invoicing

- **Job runs twice:** unique (contract_id, period_start) prevents duplicate invoices.
- **Mistake in an issued invoice:** cancel with reason, then generate a corrected one; both remain in the history.

8.7 Public certificate verification

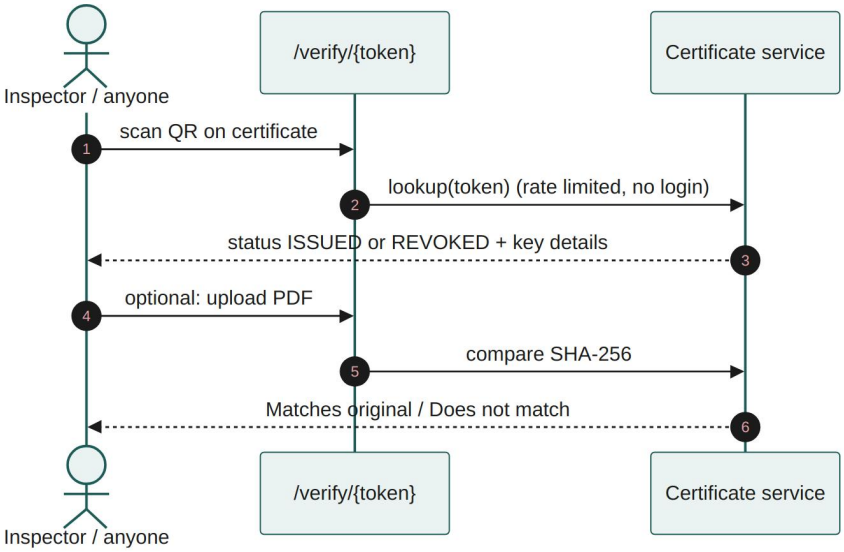


Figure 14 — Certificate verification

9. API Design

9.1 Conventions

Topic	Rule
Base path and format	`/api/...`, JSON, kebab-case paths, camelCase fields, ISO 8601 dates in UTC.
When to use what	Web forms call **Server Actions**. Driver and operator actions, tracker ingest, scheduled jobs, exports, live map and public verification use **Route Handlers**. Both call the same service functions.
Authentication	Clerk session cookie for users; per-device bearer token for trackers; `CRON_SECRET` bearer for jobs; public verification has no login but is rate limited.
Errors	`{ "error": { "code": "OTP_EXPIRED", "message": "...", "details": {} } }` with 400 bad request, 401 not signed in, 403 forbidden, 404 not found, 409 invalid transition / conflict, 422 validation, 429 rate limit, 500 unexpected.
Idempotency	Header `Idempotency-Key` (UUID) required on every driver and operator POST; replay within 24 h returns the stored response.
Pagination and filters	Cursor-based `?cursor=&limit=` (max 100); filters as query parameters (`status`, `facilityId`, `from`, `to`).
Validation	Shared zod schemas in `src/lib/validation/` used by both browser and server.

9.2 Endpoint catalogue (Route Handlers)

Method & path	Roles	Purpose
GET /api/waste/{id}/labels	hospital roles (own), super_admin	Label PDF (one QR per container)
GET /api/trips/{id}/manifest	super_admin, driver (own)	Trip manifest PDF
GET /api/driver/jobs	driver	Today's and upcoming trips with ordered stops
POST /api/trips/{id}/start	driver (assigned)	Start trip
POST /api/stops/{id}/arrive	driver	Mark arrival, geofence check, issue OTP
POST /api/stops/{id}/scan	driver	Record one container scan as SCANNED_AT_PICKUP; does not complete the stop. Requires Idempotency-Key.
POST /api/stops/{id}/verify-otp	driver	Verify OTP and, only if every expected container was scanned, atomically complete the stop and mark all containers COLLECTED.
POST /api/stops/{id}/resend-otp	driver	New code after cooldown
GET /api/hospital/active-handover	hospital_staff, hospital_admin (own)	Truck currently at the facility (ARRIVED stop), polled every 10 s
POST /api/stops/{id}/confirm-handover	hospital_staff, hospital_admin (own facility)	Fallback completion; only if every expected container was scanned. Atomically completes stop and marks all containers COLLECTED.
POST /api/stops/{id}/skip	driver, super_admin	Skip stop with reason

Method & path	Roles	Purpose
POST /api/stops/{id}/override	super_admin	Super Admin override of OTP requirement; still requires every expected container to be scanned and a written reason.
POST /api/disposal/receive	disposal_operator	Scan arriving container
POST /api/disposal/containers/{id}/exception	disposal_operator	Mark MISSING or REFUSED with reason
POST /api/disposal/waste/{id}/destroy	disposal_operator	Record destruction after all containers are accounted for; lock disposal record and enqueue certificate generation.
GET /api/certificates/{id}/pdf	hospital roles (own), staff roles, regulators	Signed download link (audited)
POST /api/certificates/{id}/revoke	super_admin	Revoke with reason
GET /api/verify/{token}	public	Certificate status and key details
POST /api/verify/{token}/check-file	public	Compare uploaded PDF hash
GET /api/tracking/live	super_admin, efda_officer	Latest position per vehicle (active trips)
GET /api/tracking/trips/{id}	super_admin, efda_officer	Route history of a trip
POST /api/tracking/v1/ingest	tracker device token	Receive position batches
GET /api/invoices/{id}/pdf	super_admin, hospital_admin (own), efda_officer	Invoice PDF
GET /api/export/{report}.(pdf|xlsx)	per report scope	Report export (audited)
GET /api/audit-logs	super_admin, efda_officer	Audit log with filters and hash-chain check
POST /api/jobs/outbox	CRON_SECRET	Send pending messages
POST /api/jobs/monthly-invoices	CRON_SECRET	Create DRAFT invoices for last month
POST /api/jobs/daily-checks	CRON_SECRET	License expiry, overdue pickups, cleanup
GET /api/health	public (no data)	Database and dependency check for monitoring
POST /api/webhooks/clerk	Clerk signature	Sync identity changes, including phone number and verification status
POST /api/trips/{id}/reassign	super_admin	Reassign only a PLANNED trip before any stop ARRIVED; cancels active OTPs and invalidates old driver actions.
POST /api/stops/{id}/cancel-active-otp	system only	Internal service operation used by skip/cancel/reassign; not a user action.

Administrative create/update screens (facilities, users, fleet, settings, trips, contracts) use Server Actions with the same services and checks.

10. Security Architecture

10.1 Authentication

- Clerk handles sign-in, sessions and password reset. Staff accounts are created by invitation only — there is no public sign-up.
- Hospital users must add and **verify a phone number in Clerk** (Clerk sends the verification code). Only verified numbers, synced to `users.phone_e164` by webhook, can receive pickup OTPs.
- Session lifetime limited; drivers and operators re-authenticate daily. Disabling a user in the system takes effect on their next request.
- Multi-factor authentication required for super_admin, who also handles billing (Clerk setting).

10.2 Authorization

- Role and facility come from the **users table**, read once per request (cached).
- Three checks on every request: middleware (signed in), area layout (role allowed in this area), and service function (`requireRole` + `requireFacilityScope`). The service check is the one that matters.
- Hospital queries always include `WHERE facility_id = currentUser.facilityId` inside the query function — never filtered afterwards in the UI.
- The EFDA Regulatory & Audit Officer has no access to any write service; tests call every write service as this role and expect 403.
- In-app handover confirmation is accepted only from a hospital user whose facility equals the stop's facility, while the stop is ARRIVED; it is audited with the user ID.
- IDs in URLs are always re-checked against the user's scope (prevents changing an ID in the address bar to see another facility).

A driver action is authorized against the current trip assignment at transaction time. UI route access is never proof that the driver is still assigned.
State-changing operational commands must carry Idempotency-Key. The idempotency record is checked and written inside the same database transaction as the business action so concurrent retries cannot perform the action twice.

10.3 Data and secret protection

- HTTPS only; HSTS; secure, HTTP-only cookies.
- Secrets only in environment variables, validated at startup; never in code or logs. Rotate any secret that was ever shared in chat or email.
- OTPs and tracker tokens stored as hashes; OTPs compared in constant time.
- PDFs in private storage, downloaded only through short-lived signed links after a permission check.
- Security headers: Content-Security-Policy (allow OSM tiles only), X-Frame-Options DENY, Referrer-Policy, Permissions-Policy (camera only on scan pages).
- Logs never contain OTP codes, tokens or full phone numbers (masked).

10.4 Abuse protection (rate limits)

What	Limit (default)
OTP verification	otp_max_attempts per code (5), then LOCKED
OTP sending	Cooldown 60 s; at most 3 codes per stop
Public verification	30 requests per minute per IP
Tracker ingest	1 request per second per device; payload size limit
Sign-in	Handled by Clerk (lockout and bot protection)

10.5 Threat model (STRIDE)

Threat	Example in this system	Mitigation
Spoofing	Someone uses a driver's stolen phone; a fake device sends positions	Session revocation and short sessions; OTP still required at pickup; per-device token, hashed
Tampering	Changing a destroyed record or a certificate PDF; editing the audit log	Workflow Engine + locked rows (trigger); SHA-256 + verify page; append-only audit with hash chain
Repudiation	Hospital denies handing over waste; driver denies a pickup	OTP proof, container scans, geofence distance, audit log with user, time and IP
Information disclosure	Hospital user views another facility; verify page leaks personal data	Facility scope in every query; verify page shows minimum data; no personal data in QR codes
Denial of service	Flooding OTP SMS or ingest endpoint	Rate limits, cooldowns, payload limits, outbox throttling
Elevation of privilege	User edits their role; regulator calls a write endpoint	Roles only in database, changed by authorized services; write services reject read-only roles

11. Integration Architecture

Every external service is reached through an **adapter** with a fixed interface. Each adapter has a real implementation and a development implementation (logs to console or simulates), selected by environment variables.

```
interface SmsProvider {
  send(to: string, text: string): Promise<{ providerRef: string }>
}
interface EmailProvider {
  send(msg: { to: string; subject: string; html: string;
              attachments?: FileRef[] }): Promise<{ providerRef: string }>
}
interface TrackingProvider {
  parse(req: Request): Promise<Position[]>   // vendor-specific format
}
interface StorageProvider {
  put(key: string, bytes: Uint8Array, type: string): Promise<void>
  signedUrl(key: string, ttlSeconds: number): Promise<string>
}
interface PdfRenderer {
  render(template: TemplateName, data: unknown): Promise<Uint8Array>
}
```

11.1 Outbox (reliable messages)

- The business change and the outbox row are saved in **one transaction** — if the change fails, no message is created; if it succeeds, the message cannot be lost.
- The outbox job sends pending messages immediately after commit (best effort) and every minute through `POST /api/jobs/outbox`.
- Retries with backoff: 1, 5, 15, 60 minutes; after the maximum attempts the message becomes FAILED and appears as an alert for the super admin.
- OTP messages expire with their code; expired OTP messages are not retried.

11.2 Integration details and failure handling

Integration	Details	Failure handling
Ethio Telecom SMS API	Account in the company's name; sender ID to be registered; one message per OTP recipient; delivery reports if supported (E11)	Outbox retry; OTP expires independently; expired messages are not retried; in-app confirmation is fallback; override is last resort.
Email	Transactional provider; company domain with SPF/DKIM	Outbox retry; alert after max attempts
GPS trackers	Vendor pending; HTTP push to ingest preferred; polling adapter if the vendor only offers an API	Adapter validates device token, payload, timestamp/clock-skew and duplicate key; invalid/replayed points are rejected; silent-tracker alert.
OpenStreetMap	Public tiles for demo; for production use a tile provider or self-hosted tiles (OSM usage policy)	Map degrades gracefully
Object storage	Private bucket; keys like `certificates/2026/CD-2026-00017.pdf`	Private bucket; certificate generation is asynchronous; FAILED/PENDING generation retried without changing the locked disposal record.

Integration	Details	Failure handling
Clerk	Invitations, sessions, phone verification, webhooks for identity and phone changes	Status message on login; data unaffected; test +251 SMS delivery early

12. Deployment and Operations

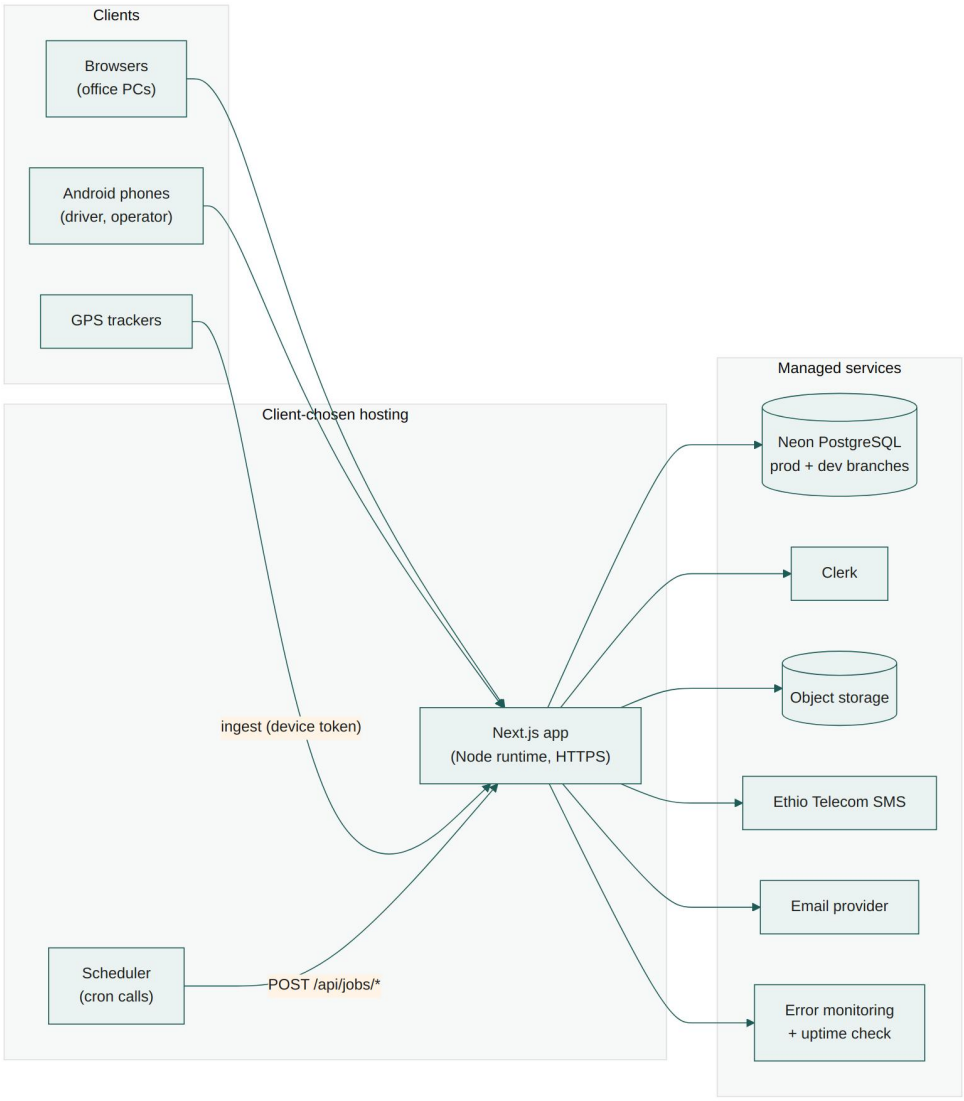


Figure 15 — Deployment view (hosting chosen by the client)

12.1 Environments

Environment	Purpose	Database	Integrations
Local	Development	Neon dev branch or local PostgreSQL	Console SMS/email, tracker simulator
Staging	Client demos, pilot testing	Neon staging branch with seed data	Real email, SMS to test numbers, simulator or real tracker
Production	Live operation	Neon production (point-in-time recovery enabled)	All real; simulator disabled

12.2 Delivery pipeline

- Every push: install → lint → typecheck → unit and integration tests → build.
- Merge to main: deploy to staging; run Playwright end-to-end tests against staging.
- Production release: manual approval; run migrations first (backward-compatible), then deploy the app; smoke test; tag the release.
- Rollback: redeploy the previous release; migrations are written so the previous version still works.

12.3 Scheduled jobs

Job	When (EAT)	What it does
outbox	Every minute	Send pending SMS and email with retries
monthly-invoices	1st of each month, 02:00	Create DRAFT invoices for the previous month
daily-checks	Daily 06:00	License expiry warnings, overdue pickups, OTP and idempotency cleanup, pending certificate retries
daily-stats (E10)	Daily 01:00	Roll up yesterday's volumes for fast regulator reports
backup-verify	Weekly	Check last backup exists; monthly restore test to a scratch branch

12.4 Monitoring and backups

- `/api/health` checks the database and reports the app version; an uptime service calls it every 5 minutes.
- Errors are sent to an error-monitoring service with the request ID; structured JSON logs.
- Alerts: app down, job failed, outbox message FAILED, tracker silent during a trip, override used.
- Backups: Neon point-in-time recovery plus a nightly export to storage; restore tested monthly (NFR-06).

12.5 Environment variables

Variable	Purpose
DATABASE_URL / DATABASE_URL_UNPOOLED	Pooled connection for the app; direct connection for migrations
CLERK_SECRET_KEY / NEXT_PUBLIC_CLERK_PUBLISHABLE_KEY / CLERK_WEBHOOK_SECRET	Authentication
SMS_PROVIDER, SMS_API_URL, SMS_API_KEY, SMS_SENDER_ID	SMS adapter
EMAIL_PROVIDER, EMAIL_API_KEY, EMAIL_FROM	Email adapter
STORAGE_PROVIDER, STORAGE_BUCKET, STORAGE_KEYS	File storage
NEXT_PUBLIC_MAP_TILE_URL, NEXT_PUBLIC_MAP_ATTRIBUTION	Map tiles
TRACKING_PROVIDER (simulator / vendor name)	Tracker adapter
CRON_SECRET, APP_BASE_URL, ERROR_MONITORING_DSN	Jobs, links in emails and QR codes, monitoring

13. Cross-cutting Concerns

Concern	Approach
Error handling	Services throw typed `AppError(code, httpStatus)`; one handler turns them into the error format; unexpected errors are logged with request ID and shown as a friendly message.
Logging	Structured JSON with request ID, user ID and role; no secrets or OTPs; masked phone numbers.
Dates and time	One helper (`src/lib/dates.ts`) for formatting in EAT; Ethiopian calendar can be added there later (E14).
Language	English UI; all labels in one dictionary file so translation can be added later; Amharic text on printed labels is a setting (E15).
Performance	SQL aggregates and indexes; no N+1 queries; dashboards stream each widget with Suspense; live map polls every 30 s; Leaflet loaded only on map pages; pagination everywhere.
Accessibility	WCAG 2.1 AA contrast; status always shown as text plus colour; keyboard navigation; large touch targets on mobile pages.
Configuration	Business values in the settings table (Appendix B), editable by super_admin and audited; technical values in environment variables.

13.1 Testing strategy

Level	What is tested	Tool
Unit	Transition table and guards, OTP rules, code formats, money and VAT calculation, date helpers	Vitest
Integration	Each service against a test database branch: scope checks, transactions, audit rows, outbox rows, idempotency	Vitest + Neon test branch
Permission matrix	Every capability × every role (Appendix C) → allowed or 403	Vitest
End-to-end	The full workflow from registration to certificate and invoice, plus failure paths, on mobile and desktop viewports	Playwright
Manual pilot	Real phones, real facilities, real signal conditions	Pilot checklist
Invariant / transaction tests	Container-count equality, no partial pickup, OTP cancellation, reassignment invalidation, certificate no-rollback, facility scope, idempotency under concurrent retry	Vitest + test database
Failure-path E2E	SMS failure, weak signal/double tap, skipped stop, reassignment, missing/refused container, certificate generation failure, tracker replay	Playwright

14. Enhancements and Version 1.2 Corrections

The original blueprint was a good base. Version 1.2 keeps the modular-monolith direction but makes the operational state machine and failure paths authoritative. Included enhancements are part of the build baseline unless explicitly marked Optional.

ID	Enhancement	Problem it solves	Cost	Status
E1	Transactional outbox for SMS/email	Messages lost when the gateway fails; slow requests while sending	Low	Included
E2	Idempotency keys on driver/operator actions	Double taps and weak signal create duplicate actions	Low	Included
E3	Geofence check at arrival (flag only)	No evidence the truck was really at the facility	Low	Included
E4	Trip manifest PDF	Proclamation 1090 expects a document accompanying each shipment	Low	Included
E5	License and permit expiry tracking	Vehicles or drivers used with expired authorizations	Low	Included
E6	OTP resend cooldown and per-stop limit	SMS flooding and guessing by repeated resends	Low	Included
E7	Overdue-pickup and silent-tracker alerts	Waste stored too long; tracking gaps unnoticed	Low	Included
E8	Audit log hash chain	Direct database tampering would be undetectable	Low	Included
E9	Health check, structured logs, error monitoring	Problems discovered only when users complain	Low	Included
E10	Daily statistics roll-up table	Slow regulator reports after years of data	Medium	Optional (when data grows)
E11	SMS delivery reports	Cannot tell whether an SMS actually arrived	Low	Optional (if gateway supports it)
E12	CSV import of facilities and users	Manual entry of 120+ facilities is slow	Low–Medium	Optional (client to confirm onboarding)
E13	Cryptographic PDF signature (PAdES)	Certificate validity checkable offline in PDF readers	Medium–High	Optional
E14	Ethiopian calendar display	Users more familiar with Ethiopian dates	Low	Optional (client to decide)
E15	Amharic text on printed labels	Labelling law expects Amharic and English	Low	Included as a setting (off by default)
E16	Automated data retention jobs	Unlimited growth of GPS and temporary data	Low	Optional (after EFDA confirms periods)

What changes in the code because of these enhancements

New tables: `licenses`, `destruction_methods`, `outbox_messages`, `idempotency_keys`. New columns: `trip_stops.arrival_distance_m`, `trip_stops.geofence_ok`, `audit_logs.prev_hash`, `audit_logs.hash`. New settings: `geofence_radius_m`, `otp_resend_cooldown_seconds`, `otp_max_per_stop`, `outbox_max_attempts`, `tracker_silent_minutes`. CLAUDE.md and PROMPT 01 have been updated to match, so the first build already creates them.

14.1 Mandatory v1.2 implementation rules

The following rules are normative. If an older figure, example, or paragraph conflicts with these rules, these rules and the transition table in Section 7 take precedence. Claude Code must not implement a conflicting flow.
No partial pickup in V1. A stop is not COLLECTED unless unique valid container scans equal the number of containers expected on that stop and every expected container is SCANNED_AT_PICKUP.
A QR scan is evidence, not final collection. The scan records a handover row and changes the container to SCANNED_AT_PICKUP. Only successful stop completion changes all containers to COLLECTED.
The expected container count for a stop is derived from all waste records linked through trip_stop_waste. The completion transaction must lock/re-check the stop and relevant container rows, recompute the count, and reject the completion if any expected container is missing, duplicated, already collected, or not SCANNED_AT_PICKUP.
OTP verification, in-app confirmation and Super Admin override use the same completion service. Only their authorization/OTP guards and collection_method differ.
Skip/cancel/reassignment invalidates every active OTP for the affected stop. Old codes can never complete a later stop.
Trip reassignment in V1 is allowed only while PLANNED and before any stop reaches ARRIVED. The former driver immediately loses authorization because the server checks current assignment.
Every disposal must account for every expected container. Each container becomes RECEIVED, MISSING or REFUSED before the waste leaves IN_TRANSIT. MISSING/REFUSED requires a reason and alert.
Destruction is irreversible at the application layer. The disposal record is locked first. Certificate PDF generation is a separate retryable operation and may never roll back or duplicate destruction.
Certificate statuses are PENDING, ISSUED, FAILED and REVOKED. Only ISSUED certificates are publicly valid; PENDING/FAILED have no public download.
Every state-changing request is server-authorized, facility-scoped where applicable, zod-validated, idempotent, audited, and executed through the Workflow Engine transaction.
No UI component, Server Component, Client Component or Route Handler may directly mutate business tables. UI/API layers call application services; services use workflow/data modules according to ownership.
External SMS, email, PDF and GPS providers must not be required to complete synchronously. Use adapters plus outbox/jobs for delivery and retryable effects.

14.2 Authoritative end-to-end system flow

Implementation connection order: hospital registration → scheduling → trip start → arrival/OTP → container scans → complete pickup → GPS transport → disposal accounting → destruction → certificate generation → billing → regulatory oversight.

Step	Connection	Authoritative rule
1. Hospital registration	Hospital UI → Access/Auth → Waste Registration Service	Create waste record + all containers as LABELLED + audit.
2. Scheduling	Admin UI → Scheduling Service → Workflow Engine	Waste becomes SCHEDULED only after readiness, license and assignment checks.
3. Trip start	Driver UI → Driver Operations → Workflow Engine	Start only for current assigned driver and valid licenses.
4. Arrival	Driver UI → Stop Service → GPS query + Workflow Engine	Record distance/geofence evidence and issue OTP through outbox.
5. Container scan	Driver scanner → Handover Service → idempotency → DB	Record SCANNED_AT_PICKUP; do not complete pickup.
6. Pickup completion	OTP/in-app/override → Handover Service → Workflow Engine	Require every expected container scan; atomically mark all COLLECTED and complete stop.
7. Transport	GPS Tracker → Tracking Adapter → GPS ingest → gps_events	Validate token, timestamp and duplicate key; associate with active trip.
8. Disposal receipt	Disposal UI → Disposal Service → Workflow Engine	Every expected container becomes RECEIVED, MISSING or REFUSED.
9. Destruction	Disposal UI → Disposal Service →	Destroy eligible containers; lock

	Workflow Engine	disposal; enqueue certificate job.
10. Certificate	Certificate Job → Certificate Service → Object Storage	PENDING/FAILED retry; ISSUED becomes publicly verifiable.
11. Billing	Monthly Job → Contract/Invoice Service → Workflow Engine → Outbox	One draft per contract/month; immutable issue/settlement history.
12. Oversight	Regulator/Admin → scoped query services	Read-only dashboards, certificates, GPS history and audit integrity.

14.3 API → service → database connection rule

Every operational command follows: Route Handler/Server Action → authenticate → load DB role/facility scope → zod validation → idempotency check → application service → Workflow Engine transaction → owned-table writes + audit + outbox → commit → response. No step may be skipped.

14.4 V1 scope decisions that prevent ambiguity

Partial pickup is OUT OF SCOPE for V1. If every expected container cannot be collected, the stop is skipped; there is no successful partial handover state.
Full offline-first driver operation is OUT OF SCOPE for V1. Authoritative completion, OTP verification and state changes require server connectivity.
Reassignment after a stop has ARRIVED is OUT OF SCOPE for V1. Use the documented exception/manual operational procedure rather than silently transferring custody.
Certificate reissue never edits the old certificate. A new certificate row is created and the previous certificate is REVOKED with reason.
Public verification exposes only certificate number, status, issue date, disposal summary and file-integrity result; no personal phone numbers or user details.

15. Risks and Open Questions

Risk	Impact	Mitigation
GPS tracker vendor not chosen	Tracking cannot go live	Adapter + simulator; ask the client to choose a vendor with an HTTP push or API before Phase 3
Ethio Telecom SMS account and sender ID take time	OTP via SMS delayed	Start the application early; email channel works meanwhile
Clerk phone verification SMS not delivered to +251 numbers	Hospital users cannot become OTP recipients	Test in the first build; fallback: Super Admin enters and verifies the number by a test SMS through Ethio Telecom
Every facility now needs a user account	Facilities without staff accounts cannot receive pickups	Onboarding plan with the client; CSV import (E12); company can invite users on behalf of facilities
Clerk and Neon store data outside Ethiopia	Possible conflict with Proclamation 1321/2024	Client to confirm before go-live; auth code isolated so it can be replaced
USD billing for cloud services	Payment difficulty for an Ethiopian company	Client to arrange payment method early
Hospitals slow to adopt	Low use, paper continues	Pilot first; simple screens; company staff can register on behalf of a facility
Scope growth on a fixed price	Delays, unpaid work	This document + signed scope; optional items need written approval
Single developer	Knowledge in one head	This document, CLAUDE.md, tests and docs updated each module

Open questions for the client

- Which GPS tracker vendor and how does it send data?
- How will 120+ facilities be onboarded (CSV import E12)?
- Should printed labels include Amharic (E15) and screens show Ethiopian dates (E14)?
- Confirm retention periods with EFDA (Section 6.4).
- Copy of the EFDA permission to issue certificates.

Appendix A — Project Folder Structure

```
neba-cs/
  CLAUDE.md                  project rules; must match this v1.2 architecture
  middleware.ts              signed-in check
  drizzle/                   versioned migrations
  docs/                      architecture, ADRs, runbooks, test evidence
  scripts/                   seed.ts, user-assign.ts, gps-simulator.ts
  src/
    env.ts                   validated environment variables
    app/                     role pages + API route handlers
    server/
      db/                    Drizzle schema and DB access
      auth/                  current user, role and facility scope
      workflow/              authoritative transition engine
      services/              waste, scheduling, handover, disposal, certificates, billing
      queries/               read-only scoped queries
      integrations/          SMS, email, GPS, storage, PDF adapters
      audit/                 append-only audit + hash chain
      outbox/                transactional outbox dispatcher
    lib/validation/          shared zod schemas
    lib/idempotency/         idempotency helpers
    lib/money/ time/ qr/     shared utilities
  tests/
    unit/ integration/ permissions/ e2e/ fixtures/
```

Appendix B — Settings and Default Values

Key	Default	Meaning
otp_expiry_minutes	10	How long an OTP is valid
otp_max_attempts	5	Wrong tries before the code is locked
otp_resend_cooldown_seconds	60	Wait before a new code can be requested
otp_max_per_stop	3	Codes per stop before only override is possible
geofence_radius_m	300	Distance counted as “at the facility”; stored as evidence, not a hard completion blocker
tracker_silent_minutes	15	No GPS during an active trip before an alert
tracker_max_clock_skew_minutes	5	Maximum accepted future timestamp skew for tracker events
overdue_pickup_days	7	Registered waste older than this is overdue
contract_expiry_warning_days	30	Warn before a contract ends
license_expiry_warning_days	30	Warn before a license expires
vat_rate_percent	15	VAT applied to new invoices
outbox_max_attempts	6	Sending attempts before a message is FAILED
label_amharic_enabled	false	Print Amharic text on labels

Appendix C — Full Permission Matrix

W = create/change, R = read, R(own) = own facility or own trips only, — = no access. HS Hospital Staff / EHO, HA Hospital Administrator, SA Super Administrator, DR Fleet Driver, DO Disposal Operator, EF EFDA Regulatory & Audit Officer.

Capability	HS	HA	SA	DR	DO	EF

Capability	HS	HA	SA	DR	DO	EF
Register / cancel waste, label containers	W(own)	W(own)	W	—	—	R
Manage own facility users and OTP recipients	—	W(own)	W	—	—	—
Manage facilities, users, fleet, trackers, settings	—	—	W	—	—	—
Create / change / cancel trips	—	—	W	R(own)	—	R
Receive pickup OTP (verified phone)	Yes	Yes	—	—	—	—
Confirm handover in-app (fallback)	W(own)	W(own)	—	—	—	—
Arrive, scan, verify OTP, skip stop	—	—	—	W(own)	—	—
Override pickup without OTP (still requires every expected container scan)	—	—	W	—	—	R
Live map (fleet radar) and route replay	—	—	R	R(own)	—	R
Receive containers, exceptions, destruction	—	—	R	—	W	R
View / download certificates	R(own)	R(own)	R	—	R	R
Revoke certificate	—	—	W	—	—	—
Contracts and invoices (ETB)	—	R(own)	W	—	—	R
Dashboards and exports	R(own)	R(own)	R	R(own)	R	R
Audit ledger and integrity check	—	—	R	—	—	R

Appendix D — Implementation Build Gates

Gate 1 — Foundation

Next.js/TypeScript strict mode, Clerk, Neon/Drizzle migrations, environment validation, database role model, CI.

Gate 2 — Core data and workflow

Facilities, users, waste, containers, Workflow Engine, audit log, idempotency. Prove invalid transitions are rejected.

Gate 3 — Pickup

Trips/stops, assignment, QR scanning, SCANNED_AT_PICKUP, OTP lifecycle, in-app fallback, override, skip and all-container invariant.

Gate 4 — Tracking

GPS adapter, simulator, timestamp validation, duplicate protection, trip association, silent tracker alerts, live/history queries.

Gate 5 — Disposal and certificates

Receipt accounting, MISSING/REFUSED exceptions, destruction lock, certificate lifecycle and public verification.

Gate 6 — Billing/reporting

Contracts, monthly invoice idempotency, VAT, PDF/Excel exports, dashboards and regulator read-only queries.

Gate 7 — Production readiness

Security review, permission matrix, failure-path E2E, backup/restore test, monitoring, provider configuration, pilot and client acceptance.